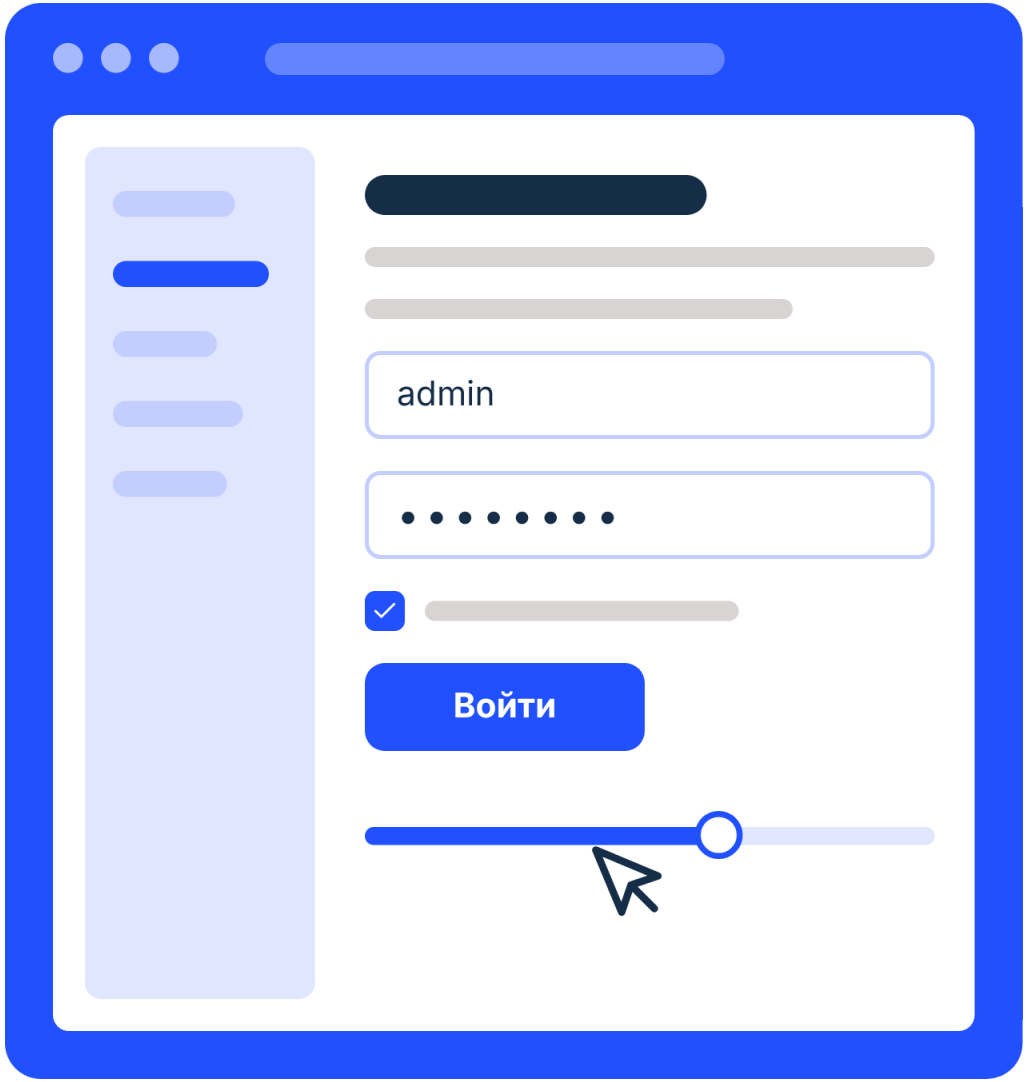
Лекция 5

Пользовательский интерфейс

Типы интерфейсов, классификация диалогов и их реализация, основные компоненты



Почему интерфейс так важен

Любая программа создаётся для человека. Когда интерфейс плох, слабым звеном становится он, даже если сама программа не дала ни одного сбоя.

Пример: консоль SIEM-системы без фильтрации событий



Что такое пользовательский интерфейс

UI (User Interface) — совокупность программных и аппаратных средств, обеспечивающих взаимодействие пользователя с программной системой.

Включает четыре уровня: отображение, ввод, правила взаимодействия и документацию



Пять свойств качественного интерфейса

Эффективность — цель с минимальными усилиями

Результативность — ожидаемый результат

Удовлетворённость — без раздражения и тревоги

Безопасность — нельзя ошибиться случайно

Доступность — для людей с ОВЗ



Свойства качества на примере антивируса

Каждое свойство превращается в конкретный вопрос к интерфейсу.



Эффективность

Как быстро запустить полную проверку?



Результативность

Карантин действительно изолирует файл?



Удовлетворённость

Не раздражают ли всплывающие окна?



Безопасность

Убедит ли поддельное окно отключить защиту?

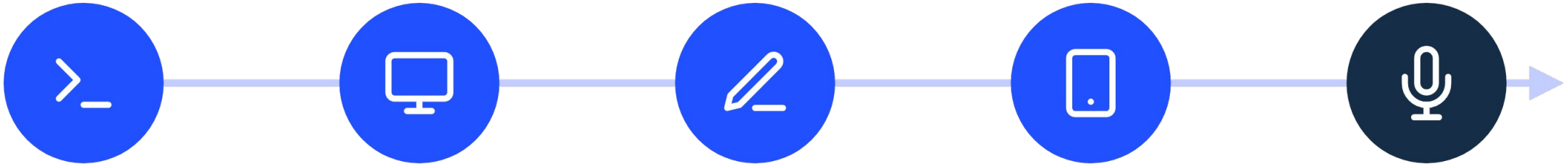


Доступность

Работает ли программа с экранным диктором?

Типы пользовательских интерфейсов

Новый тип не «отменяет» предыдущий, а занимает свою нишу.



CLI

Командный

Bash, PowerShell, Cisco

GUI

Графический

Windows, macOS, веб

Forms

На основе форм

регистрация, заявки

Touch

Жестовый

смартфоны, VR/AR, Kinect

NLI

Естественно-языковой

Siri, Алиса, чат-боты

от текстовых команд → к естественному взаимодействию. Новый тип не отменяет старый

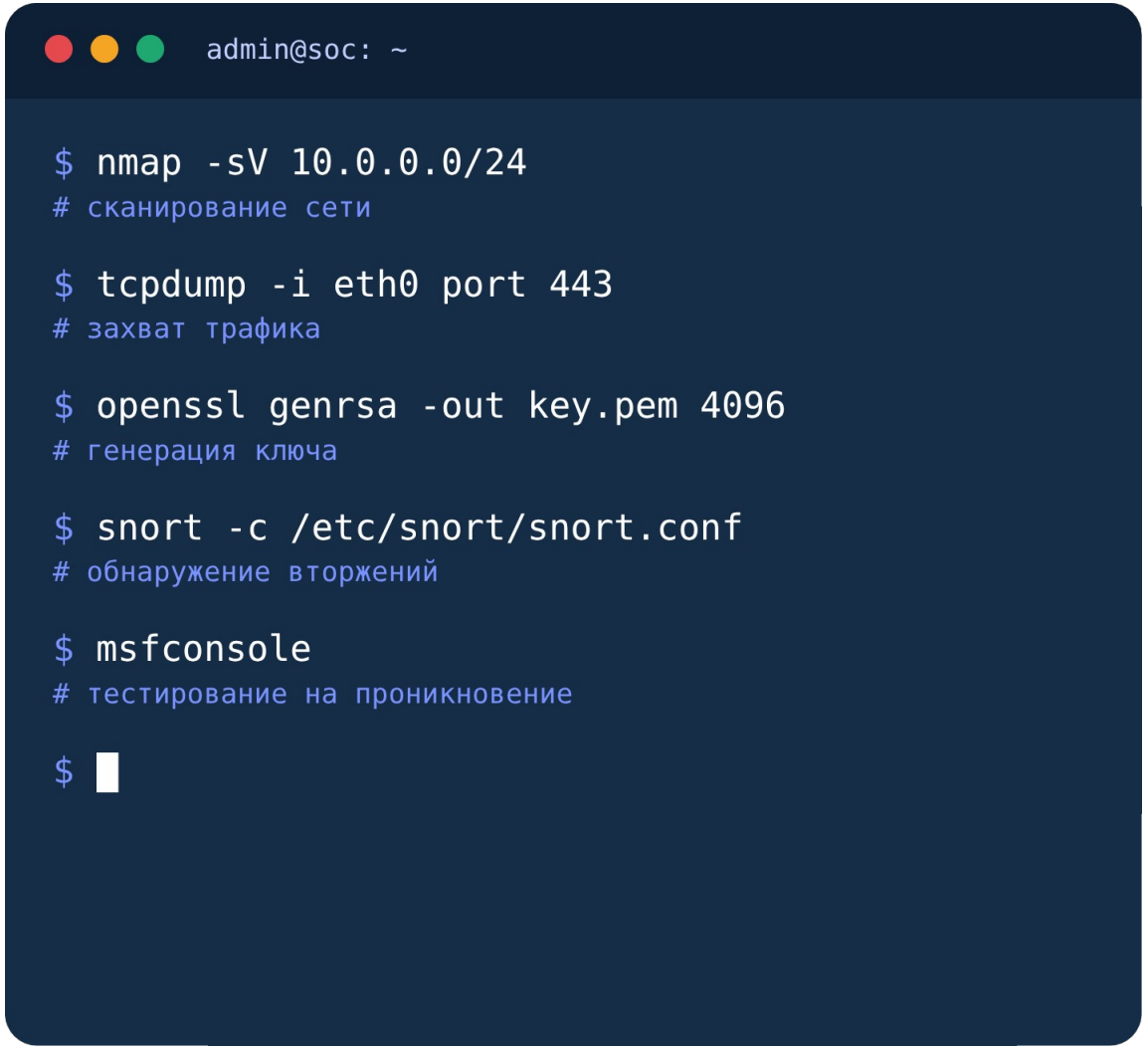
Командный интерфейс (CLI)

Пользователь вводит команды текстом, система отвечает текстом.

Bash, Zsh, PowerShell, Cisco, MikroTik

Большинство инструментов ИБ работают из командной строки

Скрипты реагирования, серверы без графики



CLI: сильные и слабые стороны

Максимум скорости и контроля — ценой высокого порога входа.

Обратная сторона: злоумышленник, получив доступ, открывает reverse shell и выполняет команды удалённо

Сильные стороны

Скорость
секунды вместо десятка кликов

Точность
ровно та команда и те параметры

Автоматизация
скрипты, массовые операции

Слабые стороны

Порог входа
нужно знать синтаксис

Мало обратной связи
ошибка может пройти молча

Цена ошибки
одна команда — сброс конфигурации

Графический интерфейс (GUI)

Окна, кнопки, меню, иконки и курсор. Windows, macOS, GNOME, KDE, веб-приложения.

Корпоративные антивирусы часто дают доступ и через GUI, и через CLI

Сильные стороны

Интуитивность
действия видны как кнопки и меню

Обратная связь
цвет, анимация, звук

Низкий порог
проще, чем CLI

Слабые стороны

Ресурсы
тяжелее и медленнее для профи

Автоматизация
поддаётся хуже

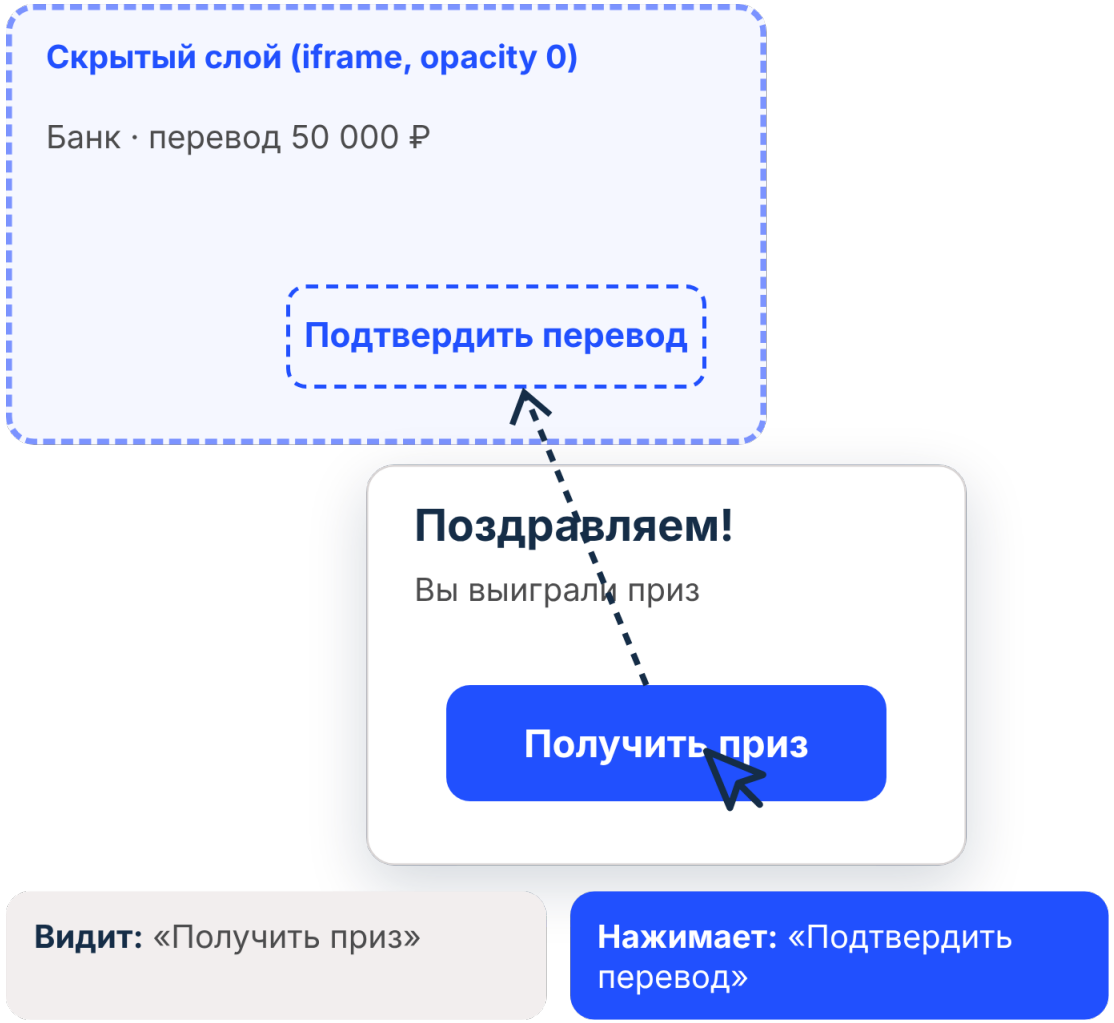
Поверхность атаки
библиотеки, события, рендеринг

Атака clickjacking

Поверх скрытой кнопки размещают привлекательную приманку.

Защита: запрет встраивания в iframe — заголовок X-Frame-Options

Корень проблемы — в интерфейсе



Естественно-языковой интерфейс (NLI)

Общение с системой на обычном языке:
Siri, Alexa, Алиса, чат-боты, LLM.

Не требует обучения, но язык многозначен

Уязвим к специфическим атакам

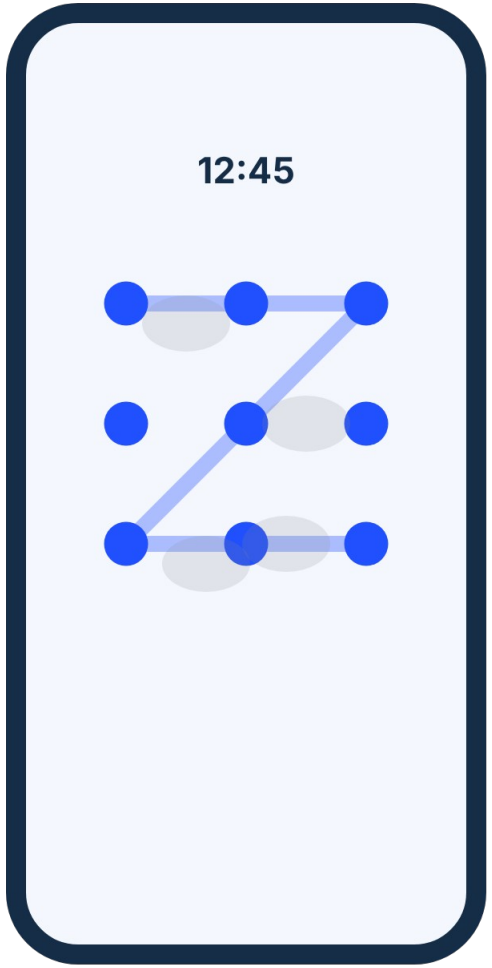


Жестовый интерфейс

Управление движениями рук, пальцев, тела: смартфоны, VR/AR, Kinect.

Удобен для работы в полевых условиях

Жест можно подсмотреть или восстановить



Перехват жеста

камера фиксирует позу при вводе графического пароля

Следы пальцев

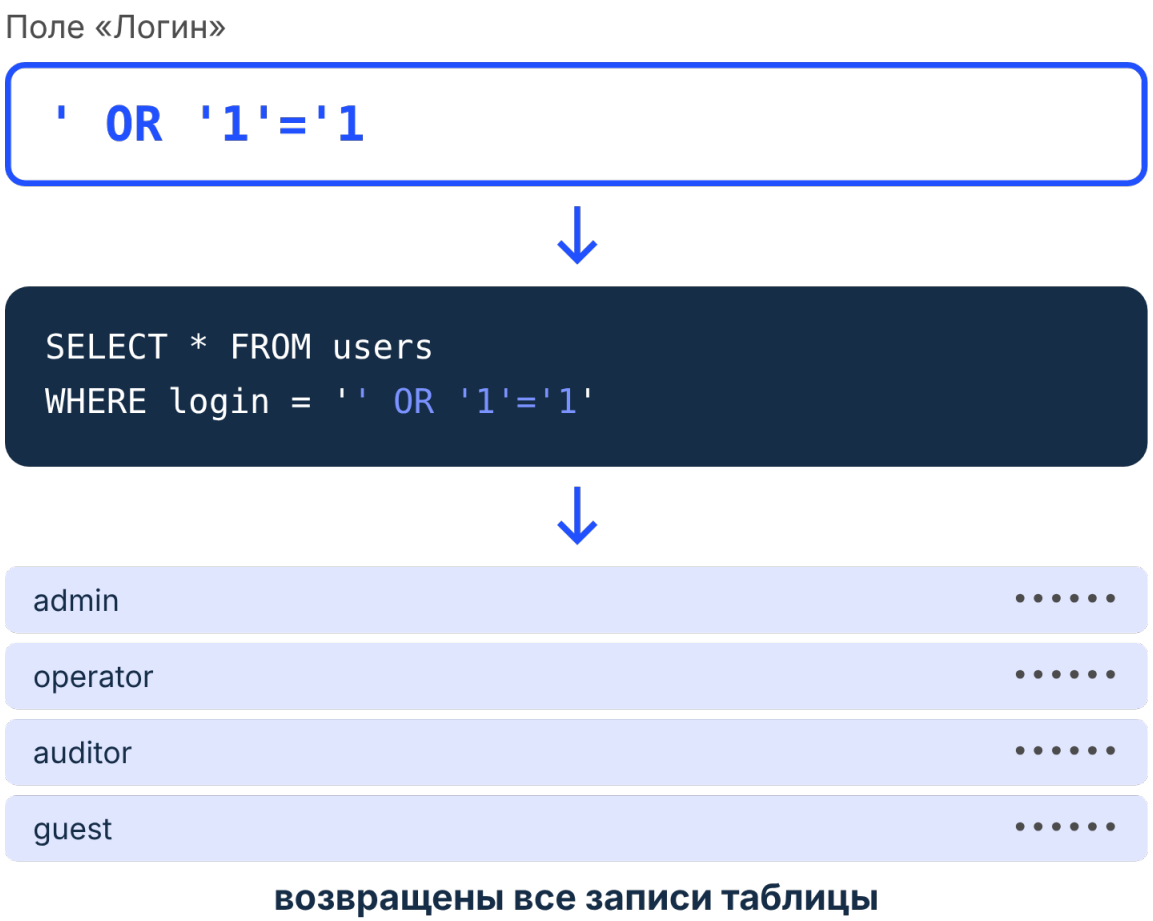
жир на стекле выдаёт жест или PIN-код

Интерфейс на основе форм

Пользователь заполняет поля, система проверяет и обрабатывает данные.

Формы — ключевая точка контроля ИБ

Защита: prepared statements, параметризованные запросы, строгая валидация

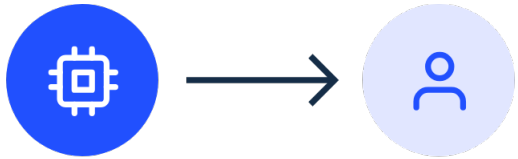


Классификация диалогов

Тип интерфейса — «форма» взаимодействия, диалог — его «содержание».



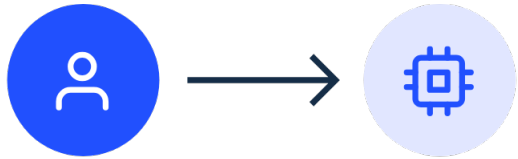
По инициатору: кто ведёт диалог



Система ведёт

мастера, установщики, опросники

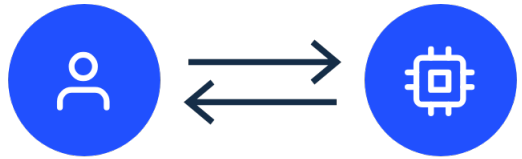
Мастер настройки МЭ: «Какие сети доверенные?»



Пользователь ведёт

командная строка

openssl: команда генерации ключа → результат

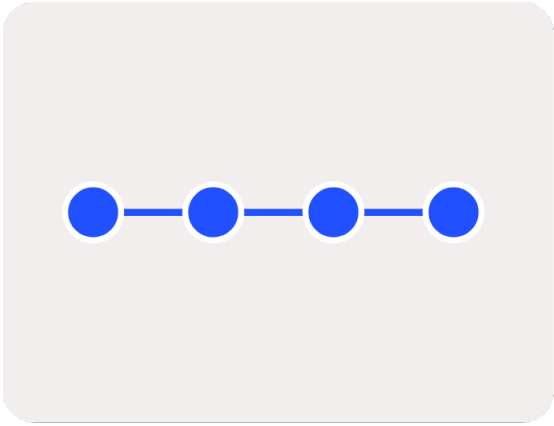


Смешанный

графические интерфейсы

Менеджер паролей: «Сгенерировать» → «Сохранить?»

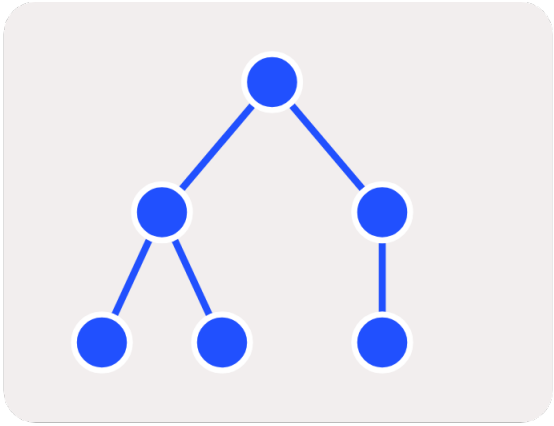
По структуре диалога



Линейный

строгая последовательность шагов

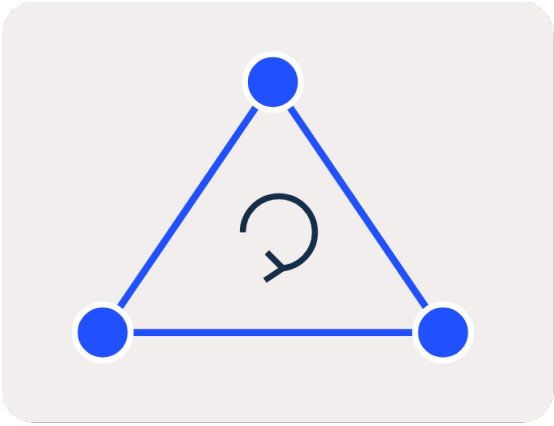
мастер установки антивируса



Древовидный

иерархия вариантов

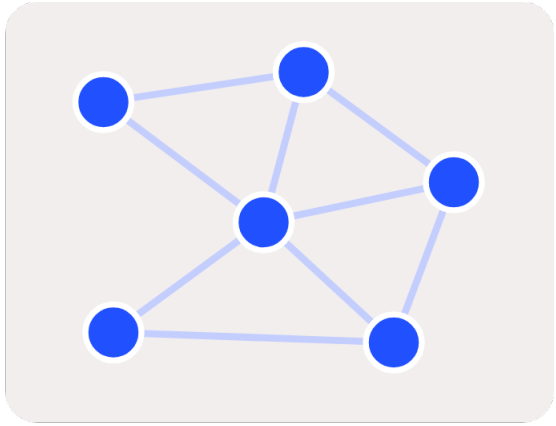
меню правил брандмауэра



Циклический

возврат к прошлым шагам

правка записи в базе уязвимостей

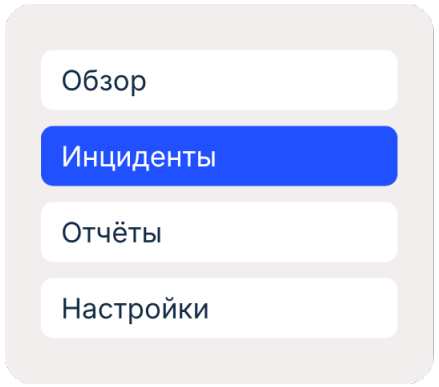


Свободный

нет фиксированной структуры

консоль Python, редактор

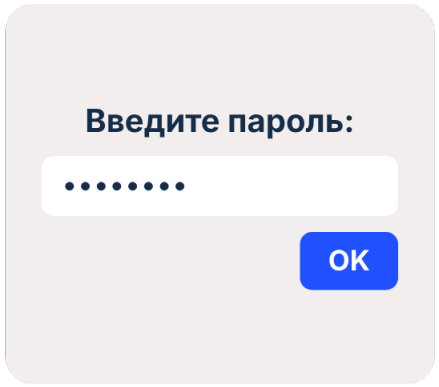
По типу взаимодействия



Меню

выбор варианта

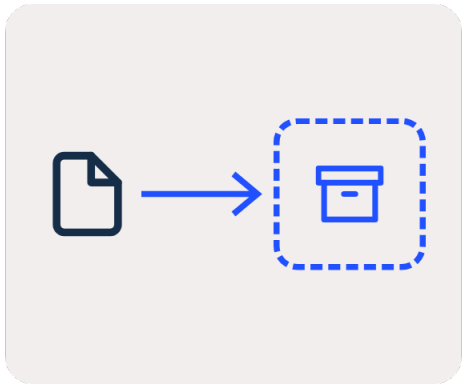
разделы консоли SIEM



Запрос-ответ

вопрос → ответ

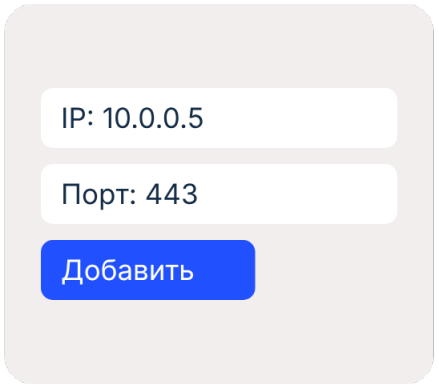
запрос пароля при входе



Прямое манипулирование

перемещение объектов

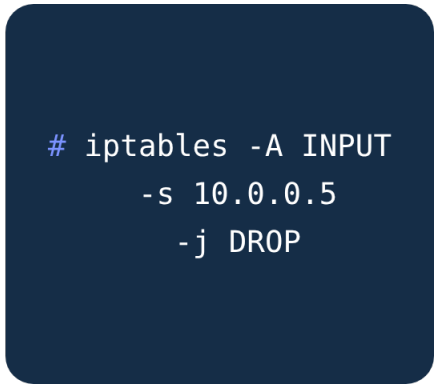
файл → в карантин



Форма

заполнение полей

новое правило фильтрации



Командный

ввод команд

правила в iptables

Реализация диалогов: пять принципов

От них зависят и удобство, и безопасность.



01

Обратная связь

реакция на каждое действие

02

Предсказуемость

одно действие — один результат

03

Отмена

Ctrl+Z, корзина, журнал

04

Подтверждение

для опасных действий

05

Сохранение состояния

данные не теряются при возврате

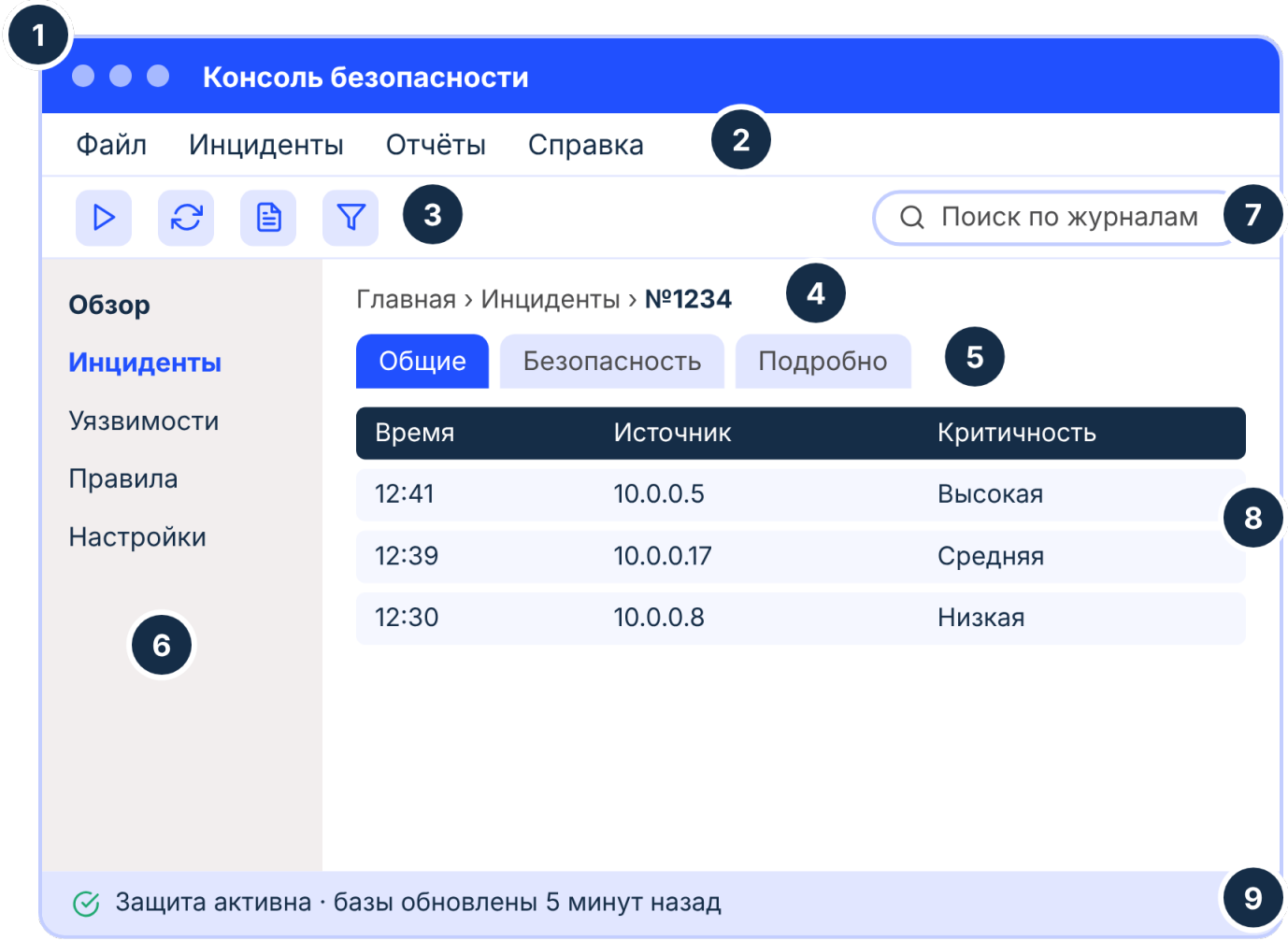
Защита диалогов от угроз

Каждой типовой угрозе соответствует своя мера защиты.

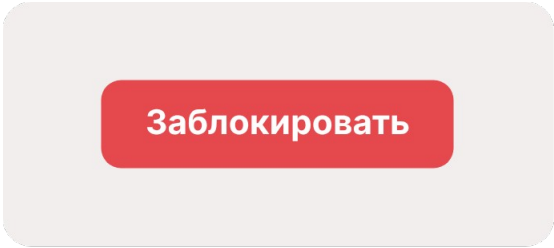


Из чего состоит интерфейс

1. Окно
2. Меню
3. Панель инструментов
4. Хлебные крошки
5. Вкладки
6. Боковая панель
7. Поиск
8. Таблица
9. Строка состояния

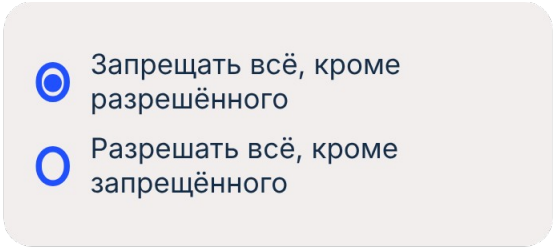


Элементы управления



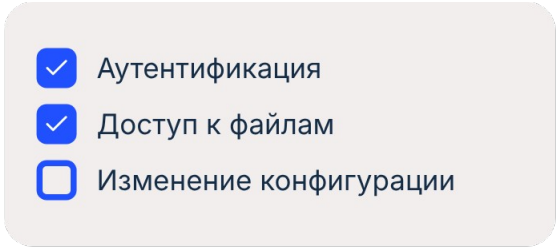
Кнопка

опасные действия — цветом и с подтверждением



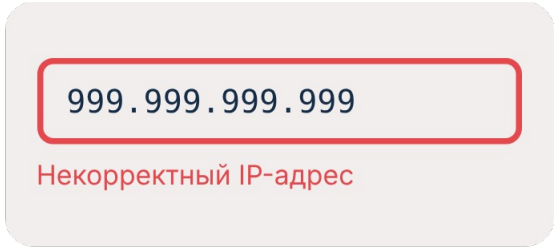
Переключатель

режим межсетевого экрана



Флажки

события для журналирования



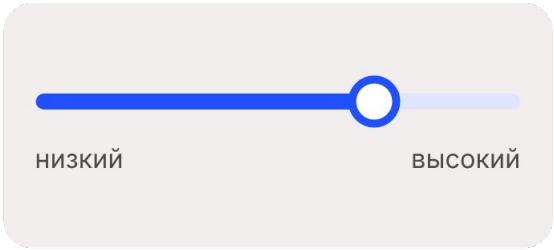
Текстовое поле

IP, маски, порты — с валидацией



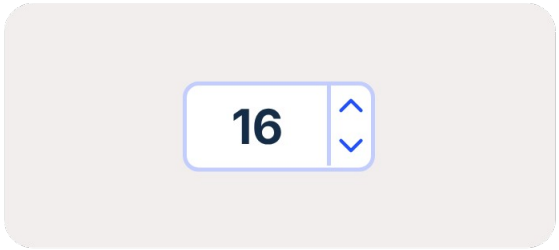
Выпадающий список

AES-128, AES-256, ГОСТ 28147-89



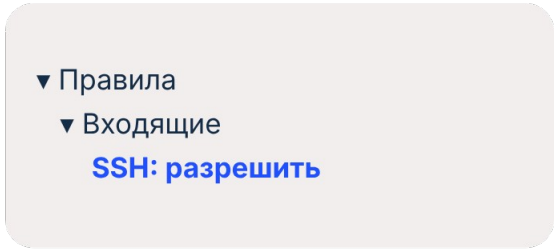
Ползунок

уровень эвристического анализа



Счётчик

длина пароля в генераторе



Дерево

иерархия правил брандмауэра

Информационные компоненты

Сообщают пользователю, что происходит в системе.

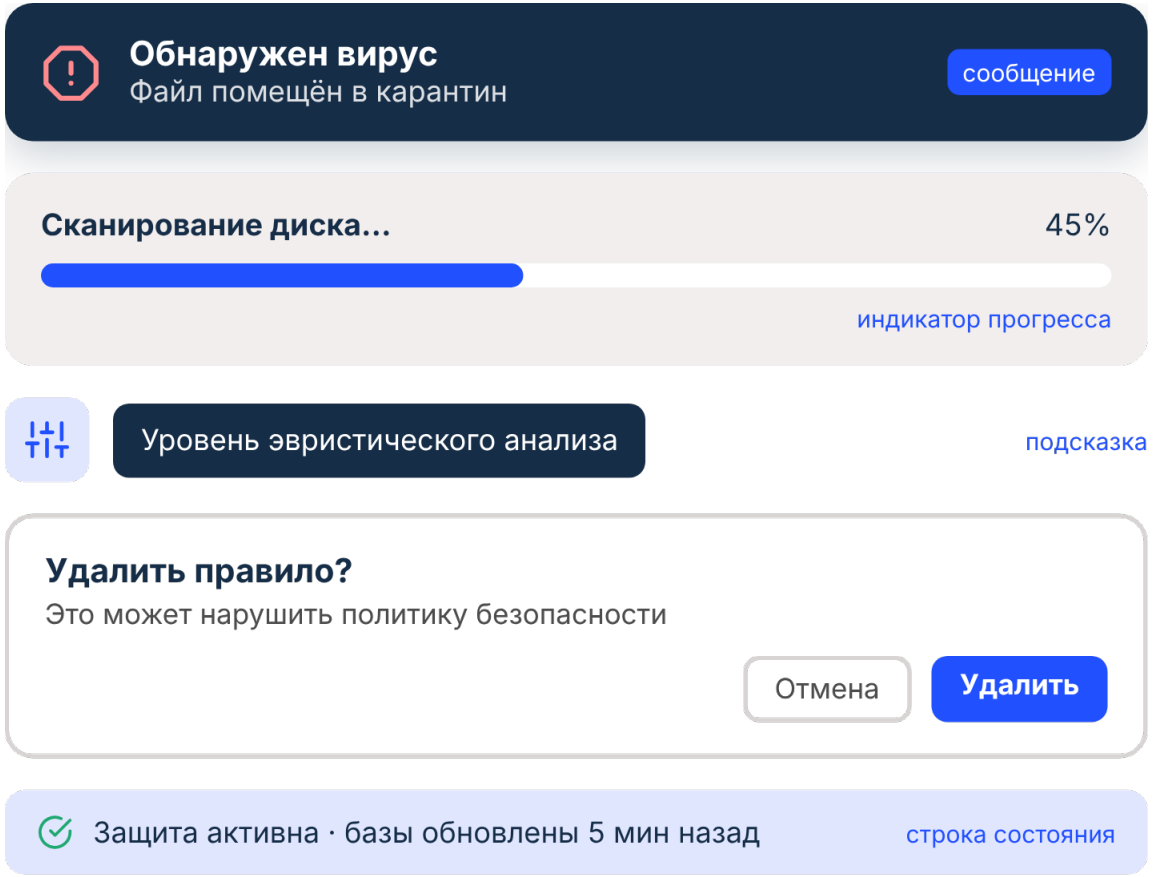
Сообщения

Индикаторы прогресса

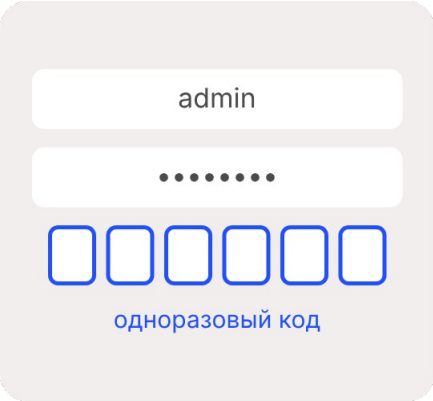
Подсказки

Диалоговые окна

Строка состояния

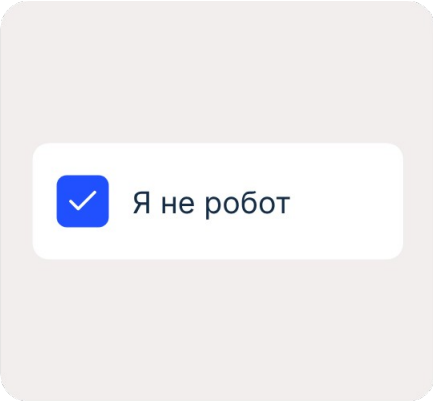


Компоненты для информационной безопасности



Аутентификация

пароль + второй фактор



Капча

барьер для ботов, но не панацея



Сложность пароля

шкала от красного до зелёного



Журнал аудита

кто, когда и что сделал



Права доступа

матрица: роль × действие

Эвристики Нильсена: 1–5

01

Видимость состояния

«Сканирование... 45%» — система работает, а не зависла

02

Язык пользователя

«Заблокировать» вместо «Установить правило deny»

03

Свобода действий

Кнопка «Отмена» в диалоге удаления

04

Единообразие

«Сохранить» всегда на одном месте

05

Предотвращение ошибок

В поле «Порт» нельзя ввести буквы

Эвристики Нильсена: 6–10

06

Узнавание, а не память

Список доступных алгоритмов шифрования

07

Гибкость

Горячие клавиши и настраиваемые панели

08

Минимализм

Консоль без мигающих баннеров и рекламы

09

Понятные ошибки

«Нет связи с 10.0.0.5» вместо «Ошибка 0x80070005»

10

Справка

Встроенный помощник с поиском

ISO 9241-210

Человеко-ориентированное проектирование:

Ориентация на пользователя

Итеративность

Мультидисциплинарность

Эргономика



Доступность (Accessibility)

Интерфейс должен подходить людям с ограниченными возможностями.

Зрение

контраст, масштаб, экранные дикторы (NVDA)

Слух

субтитры, мигающий сигнал вместо звука

Моторика

клавиатура, крупные кнопки

Когнитивные

простые формулировки, шаг назад

WCAG

ГОСТ Р 52872-2019

Угрозы безопасности интерфейса

Интерфейс — это не только удобство, но и поверхность атаки.



Меры защиты интерфейса

Ввод данных

- ✓ Валидация на сервере
- ✓ Экранирование символов

Передача

- ✓ HTTPS
- ✓ CSRF-токены

Вход в систему

- ✓ Многофакторная аутентификация
- ✓ Капча
- ✓ Лимит попыток: 5 ошибок → 15 мин

Контроль

- ✓ Аудит действий
- ✓ Регулярные обновления
- ✓ Обучение пользователей

Принципы безопасного дизайна



Минимальные привилегии

оператор видит инциденты, но не меняет правила



Разделение обязанностей

смена политики — с согласия двух админов



Защита в глубину

аутентификация + авторизация + аудит + шифрование



Отказоустойчивость

ошибки без раскрытия лишнего

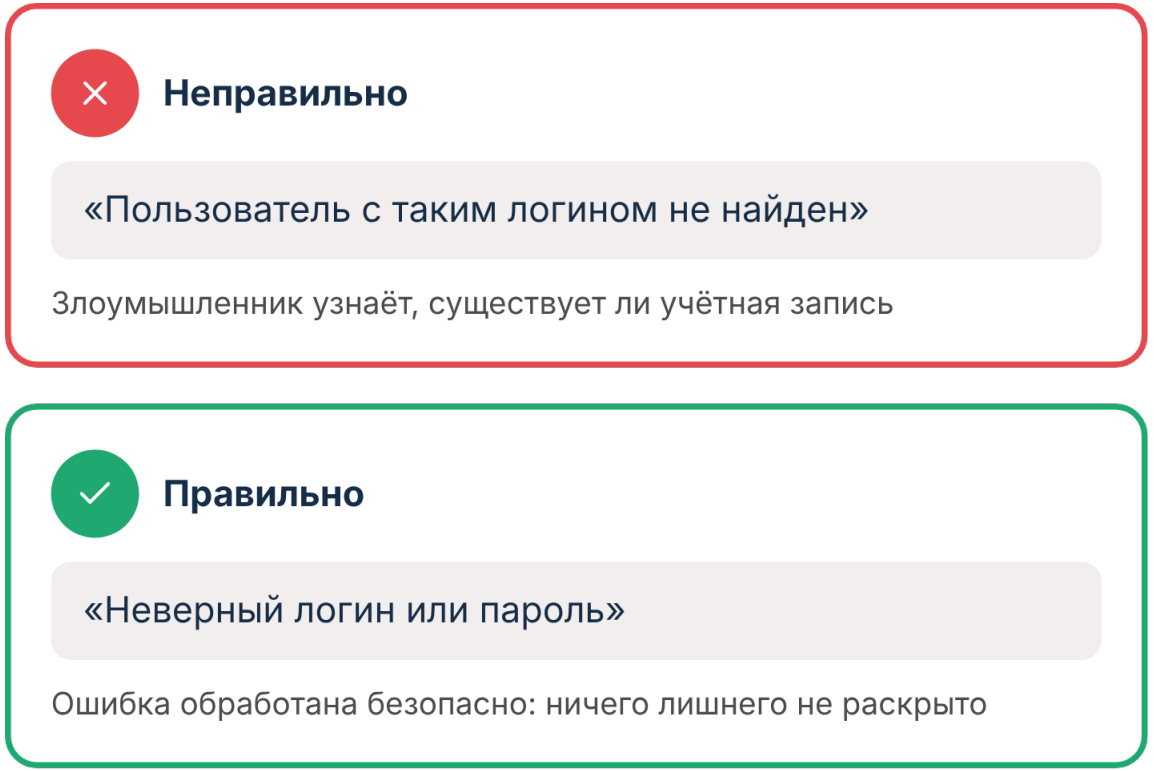


Прозрачность

видно, что затронет удаление правила

Отказоустойчивость на практике

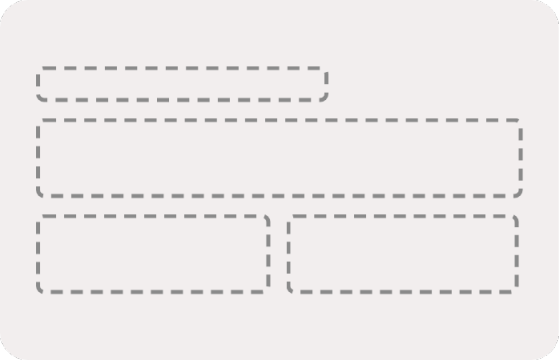
Сообщение об ошибке не должно раскрывать лишнего.



Инструменты проектирования

Для ИБ: сочетайте проектирование с **моделированием угроз** уже на этапе wireframe.

ЭТАП 1

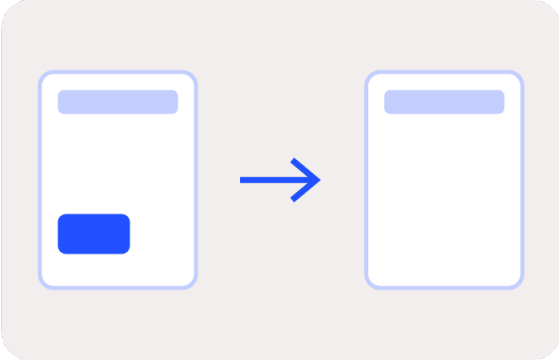


Wireframe

каркас без деталей

draw.io, Balsamiq, Figma, Pencil

ЭТАП 2

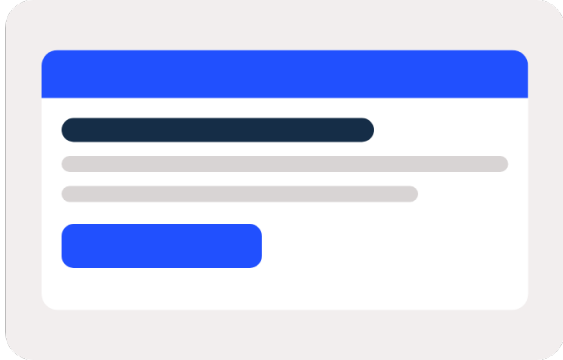


Прототип

интерактивная имитация

Figma, Axure, InVision, Marvel

ЭТАП 3

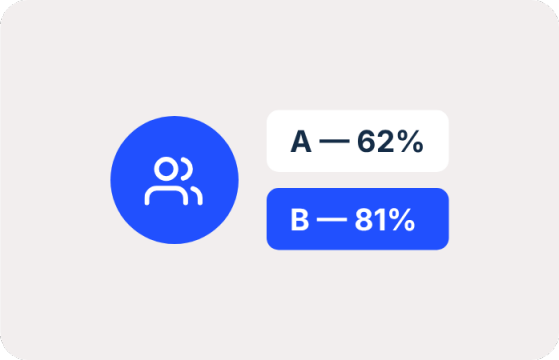


Мокап

цвета, шрифты, графика

Photoshop, Figma, Sketch

ЭТАП 4



Тестирование

проверка с пользователями

мысленный протокол, A/B, эвристики, фокус-группы

Заключение

Интерфейс — не украшение, а важнейшая функциональная часть программы.

Безопасность **закладывают с самого начала**, а не «прикручивают» в конце

